Student Exam Management System Threat Model

Owner: Emmanuel Adabra
Reviewer:
Contributors:
Date Generated: Sun Apr 26 2026

OWASP Threat Dragon

Executive Summary

High level system description

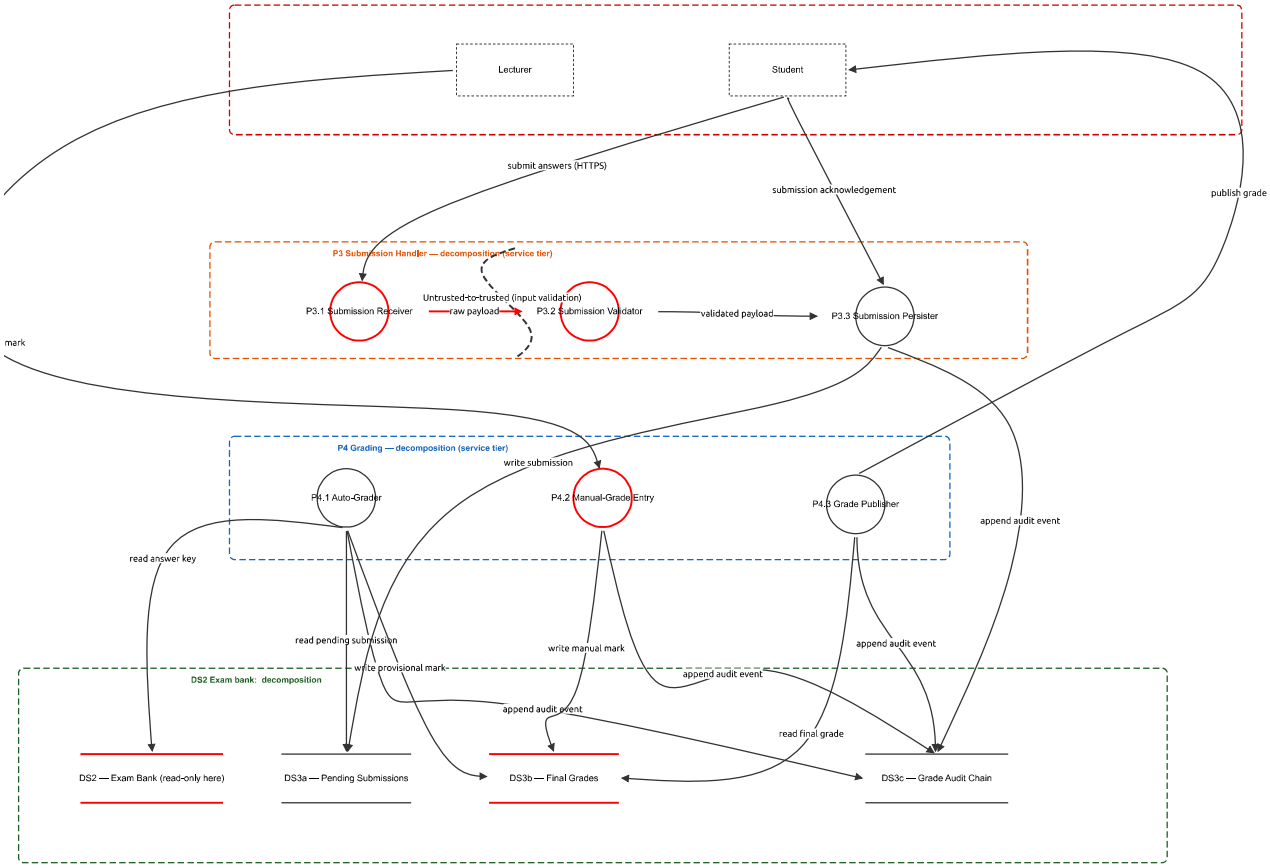
Threat model for a hypothetical web-based exam platform supporting student exam taking, lecturer exam authoring and grading, and administrator user and audit management. Federated authentication via a school identity provider

Summary

Total Threats	6
Total Mitigated	0
Total Open	6
Open / Critical Severity	1
Open / High Severity	3
Open / Medium Severity	2
Open / Low Severity	0

Level 2 — Submission and Grading

Level 2 decomposition of P3 (Submission Handler) and P4 (Grading). Exposes six sub-processes, four internal data stores, and the critical trust boundary between P3.1 (untrusted input receiver) and P3.2 (validated input). Student and Lecturer are marked out of scope — they are fully covered at Level 1.



Level 2 — Submission and Grading

P3.1 Submission Receiver (Process)

Description: HTTP endpoint that accepts POST /submit from the student over HTTPS. Receives the raw JSON payload. No validation at this stage — all input must be treated as untrusted. Hands the raw payload directly to P3.2 for validation.

Properties: Web Application, Privilege Level: Low

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	Session cookie theft enabling exam impersonation	Spoofing	High	Open	7.6	A student's session cookie is stolen via XSS in the exam interface, a compromised browser extension, or shoulder-surfing on a shared machine. The attacker replays the cookie to POST /submit on behalf of the victim, or reads in-progress answers.	HttpOnly and Secure flags on session cookies; short TTL (≤ exam window duration); Content Security Policy preventing XSS; token binding or SameSite=Strict; rotate session token on any privilege change.

P3.2 Submission Validator (Process)

Description: Validates the raw payload against the exam schema, checks the submission window is open, verifies the student owns the exam seat, and sanitises free-text input. The trust-elevation point: input north of this process is untrusted; south is structurally validated. Passes the validated payload to P3.3.

Properties: Web Application, Privilege Level: Medium

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	Submission replay — student resubmits after deadline	Tampering	Medium	Open	6.0	A student records a valid POST /submit request made before the deadline and replays it after the window closes to replace a poor answer set with a better one. P3.1 does not check the submission timestamp against the server clock; it trusts the client-supplied timestamp.	P3.2 validates the submission window server-side against a server clock, not the client timestamp; the submission payload includes a server-issued nonce that is single-use and expires at the window close; P3.3 stores a server-generated timestamp; any submission after window-close is rejected with a 403 and an audit event.

Manual-Grade Entry (Process)

Description: Accepts lecturer-authenticated HTTP requests to enter or update a manual mark for an open-ended answer. Writes the mark to DS3b. Appends an audit event to DS3c recording the lecturer identity, mark, and timestamp.

Properties: Web Application, Privilege Level: High

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	Manual-grade entry without re-authentication (P4.2 privilege escalation)	Elevation of privilege	High	Open	7.6	A lecturer's session token is long-lived. An attacker who has obtained the token (via XSS or interception) can submit manual marks through P4.2 without triggering a re-authentication challenge, elevating the effective privilege of their access to grade-writing.	Require step-up authentication (re-entry of credentials or MFA prompt) before any grade write via P4.2; session tokens for grade-entry actions have a 15-minute inactivity timeout; all grade writes are logged in DS3c with the session token fingerprint and originating IP.

DS3b — Final Grades (Store)

Description: Authoritative grade record. Stores provisional marks from P4.1, manual marks from P4.2, and the confirmed final grade. Encrypted at rest. Write access is restricted to P4.1 and P4.2; P4.3 has read-only access.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Grade tampering via direct DS3b write bypassing the grading workflow	Tampering	Critical	Open	8.0	An attacker who has compromised the grading service account (P4.1) can issue arbitrary UPDATE or INSERT statements against DS3b, writing any grade without going through the normal workflow. There is no secondary approval mechanism for grade changes once the service account has database write access.	The grading service account is restricted to a stored procedure interface — no direct table UPDATE rights; grade changes trigger a mandatory audit event in DS3c; the stored procedure validates that the mark is within the allowed range and that the exam window has closed; dual-control flag for any post-publish grade change.

DS2 — Exam Bank (read-only here) (Store)

Description: Re-drawn from Level 1 for context. At Level 2, P4.1 reads the answer key from this store. The grading service account has SELECT on answer keys only; no write access at this level.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	Pre-exam answer key exposure via unauthorised DS2 read	Information disclosure	High	Open	7.4	A student or compromised low-privilege service account reads the answer key from DS2 before the exam window opens. The grading service account used by P4.1 has broader SELECT rights than it needs, making this a viable pivot target.	Column-level access control: the grading service account has SELECT on answer-key rows only after the exam window closes; answer keys are stored encrypted with a key that is only accessible to P4.1 at grading time; all answer-key reads produce audit events in DS3c; log and alert on any out-of-window read attempt.

raw payload (Data Flow)

Description: Unvalidated student submission payload passed from the HTTP receiver to the validator. This flow crosses the L2 trust boundary — everything north is untrusted, everything south is validated.

Properties: Encrypted, Protocol (Internal)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Verbose validator error leaks payload fragments	Information disclosure	Medium	Open	6.6	When a malformed JSON submission reaches P3.2, the validator throws a parser exception whose default error message includes a fragment of the offending payload. The error is returned to the client in the HTTP response, leaking part of the submission text. In a multi-tenant exam where students cannot see each other's answers, this is a confidentiality break.	Catch parser exceptions explicitly in P3.2; return a generic 400 Bad Request with a correlation ID only; log the full error and raw payload server-side only; suppress all stack traces and exception messages from HTTP responses across the application.